IMPLEMENT AND MANAGE ZERO TRUST NETWORK ACCESS(ZTNA) USING ZSCALAR

TEAM ID: SWTID-2026-3395

s.no	Name	College	Member	Contact
1	Madhumitha E	Navarasam arts and science college for women	Team Leader	Madhumithamadhumitha980@gmail.com
2	Aarthi S	Navarasam arts and science college for women	Team Member	aarthijeni102005@gmail.com
3	Gayathri M	Navarasam arts and science college for women	Team Member	gayu31284@gmail.com
4	Kaviya P	Navarasam arts and science college for women	Team Member	kaviyaponusamy2006@gmail.com

PROJECT DETAILS

TITLE: IMPLEMENT AND MANAGE ZERO TRUST NETWORK ACCESS(ZTNA) USING ZSCALAR

Zero Trust Network Access (ZTNA) is a modern cybersecurity approach that ensures secure access to applications and resources by verifying every user and device before granting permission. Unlike traditional network security models that trust users inside the network, ZTNA follows the principle of "never trust, always verify." Organizations today face many cyber threats such as data breaches, malware attacks, and unauthorized access. To overcome these challenges, companies adopt ZTNA solutions. One of the leading platforms that provide this security model is Zscaler. By implementing ZTNA using Zscaler, organizations can protect sensitive information and control who can access specific applications or data within the network.

The Zero Trust security model assumes that no user, device, or application should be automatically trusted, even if they are inside the organization's network. Every access request must be verified using authentication methods such as identity verification, device validation, and policy checks. This approach helps organizations reduce the risk of insider threats and cyberattacks. ZTNA continuously monitors user activity and ensures that access is granted only to authorized users for specific applications. By limiting unnecessary access, the security of the entire system is significantly improved.

Implementing ZTNA with Zscaler offers several benefits to organizations. It improves security by preventing unauthorized access and reducing the chances of data breaches. It also supports remote work by allowing employees to securely access applications from any location or device. The cloud-based nature of Zscaler reduces the need for traditional VPN infrastructure and simplifies network management. Additionally, administrators can easily define security policies, monitor user activities, and control access based on roles and permissions.

ABSTRACT

The limitations of legacy VPN architectures in addressing modern security threats, particularly lateral movement and over-privileged network access, necessitate a paradigm shift towards Zero Trust principles. This project details the comprehensive design, deployment, and management of a Zero Trust Network Access (ZTNA) solution leveraging Zscaler Private Access (ZPA) within a large-scale institutional network. The project aims to replace broad network-level access with application-specific, identity-driven connectivity. By deploying Zscaler App Connectors within the data center and integrating the platform with existing Identity Providers (Azure AD) and endpoint security tools, the architecture ensures that all user-to-application connections are established through a cloud-native broker. This approach renders internal applications "invisible" to the internet, eliminating the attack surface. Furthermore, the project explores the integration of Zscaler with security ecosystems, including SIEM platforms (like QRadar) for centralized logging and MISP for consuming threat intelligence to enable adaptive access policies. The result is a robust, scalable security framework that enforces least-privilege access, provides comprehensive audit trails, and significantly enhances the institution's resilience

Use Case Scenarios:

Scenario 1: Secure Remote Access for Faculty to ERP System

A faculty member working from home needs to access the university's ERP system to upload student grades. Using Zscaler Private Access (ZPA), they connect securely without being placed on the internal network. The system verifies their identity via Azure AD MFA and checks their device posture before granting access.

Output:

• User identity verified (Faculty_Group)

• Device posture compliant (AV active, OS up-to-date)

• Secure micro-tunnel established to ERP Application only

• Network remains completely invisible to the user

Scenario 2: External Researcher Accessing a Specific Database An external research collaborator from another institution requires temporary access to a single research database hosted on VIT's servers. The administrator creates a

time-limited, application-specific policy in Zscaler. The researcher accesses only the authorized database without any visibility into the rest of the VIT network.

Output:

• External user identity verified via temporary credentials

• Access policy enforced (Time-limited: 7 days, Application: Research-DB only)

• Database server remains hidden from internet scanners

• Session automatically terminates after policy expiry

Scenario 3: Student Access to Online Examination Portal

During final exams, thousands of students simultaneously access the internal online examination portal from various locations. Zscaler ZPA ensures that only authenticated students with compliant devices can reach the exam server. The system prevents DDoS attacks on the login page and blocks any attempts to access other internal resources.

Output:

• Mass user authentication handled via cloud scalability

• Each student connected only to the exam application

• Lateral movement to grade database or other servers blocked

• Exam server IP address remains concealed from the internet

Scenario 4: IT Administrator Performing Server Maintenance

An IT administrator needs to perform critical updates on an internal application server. Instead of connecting via VPN and gaining full network access, they use ZPA to connect directly to the specific server's management interface. The session is monitored in real-time, and any anomalous behavior (e.g., accessing unauthorized servers) is automatically terminated.

Output:

• Admin identity verified with MFA

• Direct micro-tunnel to Server-Management-Interface only

• All admin keystrokes and commands logged for audit

• Attempt to access another server automatically blocked

Scenario 5: Mergers and Acquisitions – Temporary Contractor Access

A contractor hired during a university system upgrade needs temporary access to a specific file server to migrate data. Using Zscaler ZPA, the contractor is granted application-specific access without being added to the university's Active Directory or given VPN credentials. The access is revoked automatically after the project timeline.

Output:

• Contractor identity verified via separate IdP integration

• Access granted to File-Server-Migration share only

• All file transfer activities logged in Zscaler and SIEM

• Access automatically revoked after 30-day project end date

Stage-1

Overview:

The project aims to develop an AI-driven identity verification system that enhances online security by analysing and verifying user identities based on their online behaviour patterns. This system uses advanced machine learning techniques to create a robust user profile, distinguishing between legitimate users and suspicious activities. It addresses the pressing issue of unauthorised access, fraudulent transactions, and cyber threats across various online platforms and services.

The primary objective is to enhance online security significantly by scrutinising and validating user identities through their online behaviour. The system employs advanced machine learning techniques such as deep learning, neural networks, and natural language processing to establish comprehensive behavioural profiles for each user, which adapt and evolve with the user's behaviour over time. Real-time anomaly detection is a key feature of the system, identifying deviations from established user behaviour profiles and responding promptly to mitigate potential security threats.

Multi-factor verification is also implemented to bolster security, triggering additional verification steps when anomalies are detected. User and administrator alerts ensure transparent communication and provide guidance on resolving potential security issues. Secure data storage and management components are included to protect sensitive user profiles and anomaly data.

The system includes an integration layer for seamless interaction with various online platforms and services. Monitoring and reporting are integrated for performance and security, providing transparency and accountability. Scalability and load balancing are designed to handle growing user bases, while security and compliance are prioritised by encrypting data in transit and at rest, employing firewalls, intrusion detection systems, and adhering to data protection and privacy regulations.

Cloud infrastructure is an optional option for flexibility and scalability. Continuous training and optimization of machine learning models ensure the system remains effective against evolving threats and user behaviours. Geographic distribution can enhance redundancy and performance by deploying components in multiple geographic regions.

List of Vulnerability Table:

Practice Website:

S.no Vulnerability Name CWE - No
1 Improper Sanitization of File Paths CWE- 284: Improper Access
Control
2 Invalid Certificate CWE-395: Improper
Certificate Validation
3 Missing X-Frame-Options Header CWE-1021: Design
Improper Restriction of
Rendered UI Layers or
Frames
4 X-Content-Type Options Header Missing CWE -918: Server-Side
Request Forgery (SSRF)
5 Drupal Ajax API shows JSONP not disabled by
default
CWE-937,1035: OWASP
Top Ten 2013,2017 Category
A9 - Using Components with
Known Vulnerabilities

Main Website:

S.no Vulnerability Name CWE - No
1 SL Medium Strength Cipher Suites Supported
(SWEET32)
CWE-200: Exposure of
Sensitive Information to an
Unauthorised Actor
2 Cookie SERVERID created without secure flag CWE-79: Improper
Neutralisation of Input During
Web Page Generation
3 X-Content-Type Options Header Missing CWE-918: Server-Side
Request Forgery (SSRF)
4 Denial of Service CWE -400: Uncontrolled
Resource Consumption
5 OS Identification CWE-200: Exposure of
Sensitive Information to an
Unauthorised Actor

REPORT: -

Practice Website: http://www.itsecgames.com/

1)Vulnerability Name: Improper Sanitization of File Paths

CWE- 284: Improper Access Control

OWASP Category: A01:2021-Broken Access Control

Description: The product does not restrict or incorrectly restricts access to a resource from an unauthorized actor.

Business Impact: This vulnerability is significant, as it can lead to unauthorized access to sensitive data or files, potentially causing data breaches, privacy violations, and loss of user trust. Affected sites may also require configuration changes after applying a security release.

Steps to Reproduce: https://www.shodan.io/host/31.3.96.40

Recommendation:

1.Apply Security Updates: The primary recommendation is to apply the security update provided by Drupal as soon as it becomes available. Security updates typically include fixes for known vulnerabilities like this one.

2.Review Configuration: After applying the update, review your Drupal site's configuration to ensure that private files remain protected as intended. Make any necessary adjustments to your site's file permissions or access controls.

3.Regular Audits: Conduct regular security audits and vulnerability assessments to identify and address potential security issues in your Drupal site.

4.Access Control: Implement strong access controls to ensure that only authorized users can access private files. Review and restrict file access permissions as needed.

5.Data Minimization: Minimize the amount of sensitive data stored on your Drupal site. Only store data that is necessary for your site's functionality.

2)Vulnerability Name: Invalid Certificate

CWE-395: Improper Certificate Validation

OWASP Category: A07:2021 – Identification and Authentication Failures

Description: When a certificate is invalid or malicious, it might allow an attacker to spoof a trusted entity by interfering in the communication path between the host and client. The product might connect to a malicious host while believing it is a trusted host, or the product might be deceived into accepting spoofed data that appears to originate from a trusted host.

Business Impact: Improper certificate validation can lead to a range of security threats which includes Man-in-the-middle attacks(Attackers can intercept communication between two parties and read or modify the data exchanged between them),Data breaches:(Attackers can gain unauthorized access to sensitive information or sensitive systems, leading to data breaches),Malware distribution(Attackers can use fake digital certificates to distribute malicious software or infect systems with malware)

Steps to Reproduce:

https://www.ssllabs.com/ssltest/analyze?d=www.itsecgames.com

Recommendation:

1.Use trusted certificate authorities: Only trust digital certificates issued by well-known and trusted certificate authorities.

2.Verify certificate chains: Verify that the certificate presented by the remote party is valid and issued by a trusted certificate authority. Verify the entire certificate chain, including intermediate certificates.

3.Check certificate revocation status: Check the revocation status of the certificate presented by the remote party to ensure that it has not been revoked.

4.Use certificate pinning: Implement certificate pinning to ensure that the communication only occurs with the exact certificate or certificate authority specified.

5.Keep software up to date: Keep software and security protocols up to date, as new vulnerabilities and security patches are regularly released.

3)Vulnerability Name: Missing X-Frame-Options Header

CWE-1021: Design Improper Restriction of Rendered UI Layers or Frames

OWASP Category: A04:2021-Insecure Design

Description: A web application is expected to place restrictions on whether it is allowed to be rendered within frames, iframes, objects, embed or applet elements. Without the restrictions, users can be tricked into interacting with the application when they were not intending to.

Business Impact: This enables path to the attackers to manipulate or gain unauthorized access to user interface elements, potentially leading to deceptive or malicious user interactions. This can result in data leakage, fraud, user distrust, and reputational damage, undermining the integrity and trustworthiness of the application and causing financial losses.

Vulnerability Path: http://www.itsecgames.com/

Steps to Reproduce:

1.Open the practice website to inspect

2.Go to network and start capturing using F5 or Ctrl+R

3.Go to html document and see if x-frame-options present in response headers or not

4.If not the absence of this header indicates that the website may not have protection against embedding its content within an iframe on other domains, potentially leaving it vulnerable to clickjacking attacks.

Recommendation:

1.Implement Proper UI Layer Access Controls: Enforce access controls to restrict access to UI layers or frames based on user privileges.

2.Use Session and Authentication Management: Ensure robust session management and user authentication mechanisms to prevent unauthorized access.

3.Implement Content Security Policies (CSP): Use CSP headers to control where resources can be loaded from and mitigate against frame-based attacks.

4.Keep Software and Libraries Updated: Stay current with software updates and patches to address known security issues.

4)Vulnerability Name: X-Content-Type Options Header Missing

CWE -918: Server-Side Request Forgery (SSRF)

OWASP Category: A10:2021 – Server-Side Request Forgery (SSRF)

Description: The web server receives a URL or similar request from an upstream component and retrieves the contents of this URL, but it does not sufficiently ensure that the request is being sent to the expected destination.

Business Impact: The header missing impact Data Exposure (Attackers might force the server to render sensitive data as HTML, leading to data exposure), Security Risks (Content type manipulation can increase security risks, potentially leading to breaches, data leaks, and unauthorized access), Brand and Reputation Damage (Successful attacks that exploit SSRF vulnerabilities can harm the organization's reputation and trustworthiness)

Vulnerability Path:

https://securityheaders.com/?q=http%3A%2F%2Fwww.itsecgames.com%2F&followRedirects=on

Recommendation:

● Implement "X-Content-Type-Options" Header: Configure the "X-Content-Type-Options" header with the value "nosniff" in your web server or application to prevent content type sniffing.

● Secure SSRF: To directly mitigate SSRF vulnerabilities, ensure proper input validation, access controls, and allow-list-based URL validation to prevent attackers from making unauthorized requests to internal resources.

● Security Headers: Implement other security headers like "X-Frame-Options" and "Content-Security-Policy" to further enhance security and mitigate various types of web-based attacks.While the "X-Content-Type-Options" header may not be a direct countermeasure to SSRF, it is a valuable security control that, when configured correctly, can help protect against content type-based attacks that may be exploited in SSRF scenarios.

5)Vulnerability Name: Drupal Ajax API shows JSONP not disabled by default

CWE-937,1035: OWASP Top Ten 2013,2017 Category A9 - Using Components with Known Vulnerabilities

OWASP Category: A06:2021-Vulnerable and Outdated Components

Description: Vulnerable and outdated components refer to using software libraries, modules, or dependencies within a web application that have known security issues or are not updated to the latest secure versions. This can include plugins, frameworks, or APIs that are no longer maintained or have publicly documented vulnerabilities.

Business Impact: The presence of vulnerable and outdated components in a web application poses significant security risks. Attackers can exploit these weaknesses to gain unauthorized access, inject malicious code, steal sensitive data, or disrupt the system's operation. The potential business impacts include compromised user data, damaged reputation, legal consequences, and financial losses due to breach recovery and remediation efforts.

Vulnerability Path: https://www.shodan.io/host/31.3.96.40

Recommendation:

1.Regular Updates: Keep all components, libraries, and dependencies up to date by applying security patches and upgrades.

2.Vulnerability Scanning: Conduct periodic vulnerability assessments to identify and address potential issues.

3.Dependency Management: Implement a strategy for managing third-party dependencies, including continuous monitoring of their security status.

4.Security Testing: Perform regular security testing, including penetration testing and code review, to identify and remediate vulnerabilities.

5.Change Control: Maintain a change management process to assess the impact of new components and ensure they don't introduce new vulnerabilities.

6)Vulnerability Name: Drupal Api Vulnerability

CWE-20: Improper Input Validation

OWASP Category: A03:2021 – Injection

Description: The product receives input or data, but it does not validate or incorrectly validates that the input has the properties that are required to process the data safely and correctly.

Business Impact: The impact of a successful SQL injection attack can be devastating for businesses. It can result in unauthorized access to sensitive information, data theft, financial losses, damage to reputation, and legal consequences. Depending on the nature of the application and data involved, SQL injection can lead to compliance violations, customer trust erosion, and operational disruption.

Vulnerability Path: https://www.shodan.io/host/31.3.96.40

Recommendation:

1.Input Validation: Implement rigorous input validation on all user inputs and ensure that only safe, sanitized data is passed to the database.

2.Parameterized Queries: Use parameterized queries or prepared statements to separate SQL code from user input, preventing malicious injections.

3.Escaping User Input: If parameterized queries are not feasible, escape user input before incorporating it into SQL queries to neutralize special characters.

4.Least Privilege Principle: Limit the permissions and access rights of database accounts to the minimum required for specific tasks to minimize the potential damage of an attack.

5.Web Application Firewalls (WAF): Employ WAFs to filter and block malicious SQL injection attempts.

6.Regular Security Testing: Conduct regular security assessments, including penetration testing, to identify and address vulnerabilities.

7)Vulnerability Name: Improper API Filtration

CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')

OWASP Category: A07-2017: Cross-site Scripting (XSS)

Description: The product does not neutralize or incorrectly neutralizes user-controllable input before it is placed in output that is used as a web page that is served to other users.

Business Impact: If exploited, this vulnerability allows attackers to inject malicious scripts into web pages, which can be viewed by other users. The potential business impacts include data theft, unauthorized access, compromised user accounts, damaged reputation, and financial losses. Attackers can use XSS to steal sensitive information, such as user credentials, personal data, or financial details, leading to regulatory compliance violations and legal liabilities. Additionally, defacement or manipulation of website content can erode customer trust and result in lost revenue.

Vulnerability Path: https://www.shodan.io/host/31.3.96.40

Recommendation:

1.Update and Patch: Ensure that Drupal and all related modules and components are up to date with the latest security patches to mitigate known vulnerabilities.

2.Input Validation: Implement strong input validation and output encoding to sanitize user inputs and prevent the injection of malicious scripts.

3.Content Security Policy (CSP): Implement CSP headers to restrict the sources from which content can be loaded, reducing the risk of XSS.

4.Secure Coding Practices: Train developers in secure coding practices, emphasizing the importance of validating and escaping user inputs.

5.Security Scanning: Conduct regular security scans and penetration tests to identify and address XSS vulnerabilities.

Conclusion: -

In conclusion, exploring the realm of AI for web security using IBM QRadar has been an insightful journey through various stages.

In Stage 1, understanding web application testing unveiled the critical importance of assessing vulnerabilities and ensuring the security of web-based systems. This foundational knowledge served as a cornerstone for comprehending the subsequent stages.

Future Scope: -

Future of web application testing

The future of WAT is bright, as web applications become increasingly complex and sophisticated. Organizations are increasingly reliant on web applications to conduct business, and they need to be confident that their web applications are secure and reliable.

Here are some of the key trends that are expected to shape the future of WAT:

● Increased focus on security: Security is a top priority for all organizations, and WAT is essential for identifying and mitigating security vulnerabilities. In the future, we can expect to see even more emphasis on security testing, as web applications become increasingly targeted by cyberattacks.

● Rise of artificial intelligence (AI) and machine learning (ML): AI and ML are already being used in WAT, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.

● Shift to cloud-based testing: More and more organizations are moving their web applications to the cloud. This trend is driving the growth of cloud-based WAT platforms. Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness.

● Increased focus on user experience (UX) testing: UX testing is essential for ensuring that web applications are easy to use and meet the needs of users. In the future, we can expect to see more focus on UX testing, as organizations increasingly recognize the importance of providing a positive user experience.

Future scope of the testing process

The future scope of the testing process is bright, as software becomes increasingly complex and sophisticated. Organisations are increasingly reliant on software to conduct business, and they need to be confident that their software is high-quality and reliable.

Here are some of the key trends that are expected to shape the future of the testing process:

● Increased focus on continuous testing: Continuous testing is a methodology that involves testing software throughout the SDLC, from development to deployment. This helps to identify defects early and prevent them from causing problems later in the development process.

● Rise of AI and ML: AI and ML are already being used in the testing process, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.

● Shift to cloud-based testing: Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness. This is driving the growth of cloud-based testing platforms.

● Increased focus on testing automation: Testing automation is the use of software to execute test cases without human intervention. Testing automation can help to save time and resources, and it can also help to improve the quality and efficiency of testing.

Future scope of SOC / SEIM:-

The future scope of Zero Trust Network Access (ZTNA) and the broader Zero Trust framework is poised for significant evolution, driven by emerging technologies and changing threat landscapes:

1. AI-Driven Zero Trust (AI-ZTA): Future Zero Trust implementations will leverage advanced AI and deep learning to move beyond static policies. Systems will continuously learn user behavior, predict anomalous activities before they occur, and dynamically adjust access privileges in real-time based on contextual risk, creating a truly "adaptive" security posture.

2. Integration with Edge Computing and IoT: As organizations deploy more IoT devices and edge computing nodes, Zero Trust principles will extend to these resource-constrained environments. Expect the development of lightweight Zero Trust agents and protocols that can authenticate and secure machine-to-machine (M2M) communication at the edge, preventing large-scale botnet attacks.

3. Identity-Centric Everything: The future will see identity become the ultimate security perimeter. Zero Trust will evolve to incorporate advanced identity verification methods, including continuous behavioral biometrics (keystroke dynamics, gait analysis) and decentralized identity solutions using blockchain, ensuring that the user behind the session is verified at all times.

4. Convergence with SASE Architecture: Zero Trust will be a core component of the Secure Access Service Edge (SASE) framework. This convergence will provide organizations with a unified, cloud-delivered stack that combines ZTNA, Secure Web Gateways (SWG), Cloud Access Security

Brokers (CASB), and Firewall-as-a-Service (FWaaS), simplifying management and ensuring consistent security for all users, regardless of location.

5. Zero Trust for Operational Technology (OT) and Critical Infrastructure: Sectors like energy, manufacturing, and healthcare will increasingly adopt Zero Trust to protect critical infrastructure. Future scope includes air-gapped Zero Trust solutions and specialized protocols designed to secure legacy industrial control systems (ICS) and SCADA environments from nation-state attacks.

6. Automated Threat Hunting and Response: Future Zero Trust platforms will integrate with Security Orchestration, Automation, and Response (SOAR) tools to enable automated threat hunting. Upon detecting a compromised identity or device, the system will not just block access but automatically initiate investigation playbooks, isolate affected systems, and even roll back malicious changes.

Topics explored: -

Data Collection and Aggregation, Standardization and Normalisation, Enrichment and Analysis, Sharing and Distribution, Integration with Security Tools, Customization and Flexibility, Automation and Orchestration, Community Involvement, Incident Response Support, Threat Intelligence Feeds, Soc and Siem

Tools explored: -

Nmap, Metasploit, Nessus, Kali Linux, OWASP ZAP, Burp Suite

THE END